Instruções de Segurança

Hub de IA Local para Fábrica de Software

Objetivo: estabelecer controles de segurança para o uso de uma IA local destinada às três equipes de desenvolvimento, com foco na proteção de código, confidencialidade, controle de acesso, auditoria e redução da exposição de dados.

> **Princípio central — Security by Design:** o fato de o processamento ser local reduz a exposição a serviços externos, mas não torna o sistema automaticamente seguro. A segurança depende da arquitetura, configuração e controles implementados.

1. Controle de acesso

• Utilizar uma conta individual para cada desenvolvedor; evitar contas compartilhadas.

• Implementar autenticação antes de permitir acesso ao Hub.

• Aplicar o princípio do menor privilégio: cada usuário deve possuir somente os acessos necessários.

• Controlar o acesso por equipe e, quando necessário, por projeto.

• Revogar imediatamente o acesso quando houver desligamento ou mudança de função.

• Proteger sessões com expiração e mecanismos contra tentativas repetidas de autenticação.

2. Isolamento e segurança da rede

• Manter o servidor de IA fora da exposição direta à Internet.

• Usar firewall para permitir somente as conexões necessárias.

• Fechar portas e serviços que não sejam necessários.

• Não expor diretamente a API do Ollama aos computadores dos usuários quando houver um backend intermediário.

• Restringir o acesso administrativo ao servidor a administradores autorizados.

3. Arquitetura recomendada de acesso à IA

• **Desenvolvedor** → **Interface/Backend** → **Autenticação** → **Autorização** → **Validação** → **Ollama** → **Modelo**

• Essa arquitetura permite colocar os controles de segurança antes do modelo, em vez de deixar cada usuário acessar diretamente o serviço de inferência.

4. Proteção de prompts, código e histórico

• Definir uma política clara sobre o que pode ser enviado à IA.

• Evitar armazenar o conteúdo completo de prompts e respostas quando isso não for necessário.

• Definir prazo de retenção para registros que precisem ser mantidos.

• Restringir o acesso aos históricos e logs.

• Não registrar senhas, tokens, chaves privadas ou outros segredos em logs.

• Avaliar cuidadosamente qualquer funcionalidade futura de histórico ou reutilização de conhecimento.

5. DLP e dados sensíveis

Como evolução de segurança, o Hub pode identificar dados potencialmente sensíveis antes do processamento.

Categoria	Exemplos	Ação sugerida
Credenciais	senhas, API Keys, tokens	alertar ou mascarar
Chaves	chaves privadas, certificados	bloquear ou mascarar
Dados pessoais	CPF, e-mail e identificadores	avaliar necessidade e mascarar
Banco/infra	connection strings, credenciais de BD	alertar ou bloquear

6. Segurança específica da IA

• **Prompt Injection:** tratar conteúdo fornecido pelo usuário como dados e não como autoridade para alterar as regras do sistema.

• Separar instruções do sistema, regras de segurança, solicitação do usuário e dados/código fornecidos.

• Evitar que o modelo tenha acesso desnecessário a sistemas, arquivos ou informações internas.

• Monitorar comportamentos anômalos e tentativas de abuso.

• Revisar respostas da IA antes de aplicar automaticamente alterações em código.

7. Logs e auditoria

Registrar eventos suficientes para investigação sem transformar os logs em uma cópia do código confidencial.

Evento	Recomendação
Login / logout	Registrar
Usuário e equipe	Registrar
Data e horário	Registrar
Quantidade de solicitações	Registrar
Tempo de processamento	Registrar
Erros e falhas	Registrar
Tentativas de acesso indevido	Registrar e alertar
Prompt/código completo	Evitar armazenamento desnecessário

8. Segurança do servidor

• Manter sistema operacional e componentes atualizados com patches de segurança.

• Usar firewall e restringir serviços expostos.

• Proteger SSH e limitar o acesso administrativo.

• Usar contas administrativas separadas das contas comuns.

• Considerar criptografia do armazenamento, conforme a infraestrutura disponível.

• Utilizar monitoramento e EDR/antivírus quando aplicável ao ambiente.

• Documentar mudanças de configuração relevantes.

9. Backup e recuperação

• Definir quais configurações e dados realmente precisam de backup.

• Manter backups separados do servidor principal.

• Restringir o acesso aos backups.

• Testar periodicamente a restauração.

• Definir procedimento para recuperação após falha, comprometimento ou indisponibilidade.

10. LGPD e confidencialidade

• O projeto atende um contexto em que existem clientes como bancos e universidades e em que código e prompts podem possuir caráter confidencial.

• A arquitetura local reduz a necessidade de enviar esses dados para fornecedores externos, mas as políticas internas de tratamento de dados, contratos e requisitos de cada cliente devem continuar sendo observados.

11. Controles prioritários para o MVP

Prioridade	Controle
Alta	Acesso autenticado e individual
Alta	Servidor não exposto à Internet
Alta	Firewall e portas mínimas
Alta	Ollama protegido atrás do backend
Alta	Revogação de usuários desligados
Alta	Não registrar segredos em logs
Média	Auditoria de acessos e uso
Média	Detecção/mascaramento de dados sensíveis
Média	Backups e teste de restauração
Evolução	DLP mais avançado e métricas por equipe/projeto